Security Organization Development

a. Organizational Structure

The bank's cybersecurity structure must address its legacy systems, cloud applications, compliance requirements, and the evolving threat landscape. A **hybrid (centralized-decentralized) model** is best suited, ensuring global consistency while allowing regional flexibility for regulatory requirements.

Top-Level Cybersecurity Leadership

Chief Information Security Officer (CISO)

Reports to: Chief Information Officer (CIO), Board of Directors & CEO

Responsibilities:

- Develop and oversee global cybersecurity strategy.
- Ensure compliance with PCI-DSS, GDPR, SOX, and other regulations.
- Lead crisis management for cybersecurity incidents.
- Report security posture and risk assessments to the board.

Global Cybersecurity Divisions

1. **Security Governance & Compliance (SGC)**
    - *Director of Security Compliance & Risk Management* (Reports to CISO)
    - Ensures adherence to banking regulations in 30+ jurisdictions.
    - Oversees internal audits, risk assessments, and policy development.
    - Works closely with Legal and Regulatory Affairs teams.
2. **Threat Intelligence & Incident Response (TIIR)**
    - *Global Threat Intelligence Director* (Reports to CISO)
    - Monitors and analyses cyber threats targeting financial institutions.
    - Runs a 24/7 Security Operations Center (SOC) with regional hubs.

    - Coordinates threat intelligence sharing with government and financial sector bodies.
3. **Security Architecture & Engineering (SAE)**
    - *Head of Security Architecture & Engineering* (Reports to CISO)
    - Manages the security of cloud applications and legacy mainframes.
    - Develops secure integration frameworks for legacy and modern systems.
    - Implements Zero Trust Architecture.
4. **Identity & Access Management (IAM)**
    - *Director of IAM* (Reports to CISO)
    - Manages authentication systems, privileged access management, and user provisioning.
    - Ensures compliance with multi-factor authentication (MFA) and access control regulations.
5. **Cybersecurity Operations & SOC (CSO-SOC)**
    - *Global Head of Security Operations* (Reports to CISO)
    - Runs Tier-1, Tier-2, and Tier-3 SOC analysts across different time zones.
    - Leads forensic analysis, malware analysis, and threat hunting teams.
    - Oversees security event correlation and SIEM management.
6. **Regional Security Officers (RSOs)**
    - *Reports to CISO and respective Regional Leadership*
    - Responsible for country-specific security implementations.
    - Ensures adherence to regional data residency laws.
    - Works with local regulators and banking authorities.

2. Reporting Relationships & Communication Channels

- **CISO Reports Directly to Board of Directors & CIO** for strategic security decisions.
- **Security Governance & Compliance Team** collaborates with **Legal & Risk Management** teams.
- **Threat Intelligence & Incident Response** shares intelligence across **Security Operations & SOC**.

- **Regional Security Officers (RSOs)** report to the CISO and **Regional Leadership Teams**.
- **Regular Security Briefings & Threat Reports** shared with senior executives & board.

3. Justification for the Hybrid Security Model

- **Centralized Control** ensures consistent enforcement of global security policies.
- **Decentralized Regional Security Officers (RSOs)** handle country-specific compliance and regulatory challenges.
- **Legacy System Considerations:** The hybrid model allows secure integration between legacy and cloud systems.
- **Threat Landscape Justification:** A hybrid SOC ensures **24/7 monitoring** across time zones to detect & respond to global threats.
- **Regulatory Compliance:** The combination of **central governance and local enforcement** ensures adherence to international and country-specific regulations.

Conclusion

This cybersecurity organizational structure aligns with the bank's global presence, regulatory complexity, and security threats. It provides a balance between **centralized security governance** and **decentralized execution**, ensuring agility, compliance, and resilience against evolving cyber threats.

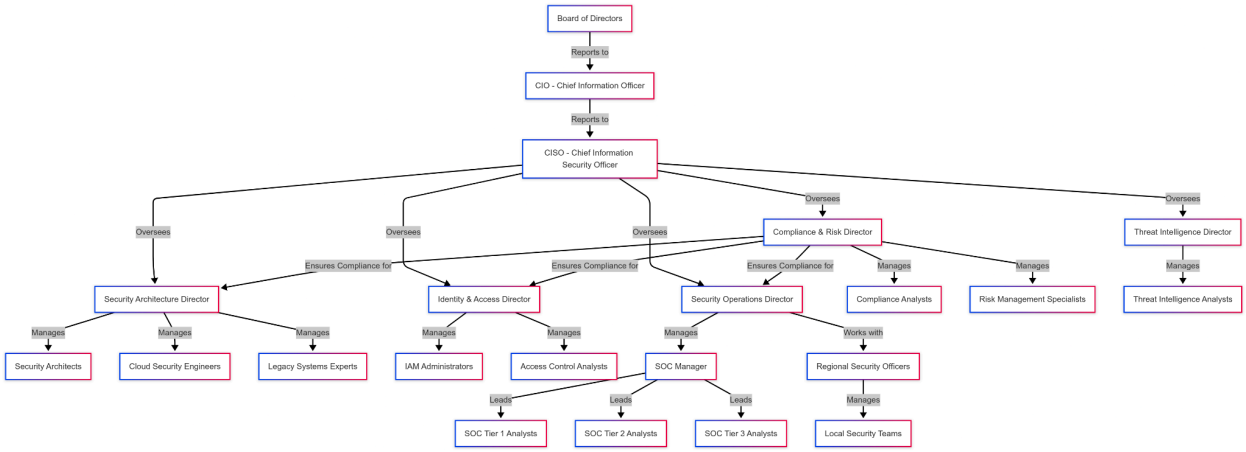


Image Link: [click here]

b. Key Cybersecurity Positions and Their Roles & Responsibilities

1. Chief Information Security Officer (CISO)

Responsibilities:

- Develop and oversee the bank's global cybersecurity strategy.
- Ensure compliance with **PCI-DSS, GDPR, SOX**, and country-specific regulations.
- Report security risks and incidents to the board and senior executives.
- Lead crisis response for cyber incidents.
- Oversee cybersecurity investments and initiatives.

Why It's Critical:

- A **strategic leader** ensuring security is aligned with business goals.
- Balances **compliance, threat detection, and risk management** at a global scale.

Required Skills/Certifications:

- CISSP, CISM, or CISA preferred.
- Strong regulatory and banking cybersecurity experience.

2. Director of Security Compliance & Risk Management

Responsibilities:

- Ensure all banking security policies meet global and local regulations.
- Conduct audits and risk assessments.
- Work with **legal and regulatory bodies** to ensure compliance.
- Develop incident response and disaster recovery policies.

Why It's Critical:

- Banks face **strict compliance regulations**, and failure can lead to heavy fines.
- Manages **risk assessment** for legacy and modern systems.

Required Skills/Certifications:

- CISA, CRISC, or CIPM preferred.
- Strong knowledge of financial cybersecurity laws.

3. Global Threat Intelligence Director

Responsibilities:

- Analyse global cyber threats affecting the banking sector.
- Work with **law enforcement and security agencies** to track cybercriminal activities.
- Share threat intelligence across **SOC teams and security leaders**.

Why It's Critical:

- Financial institutions are targeted by **nation-state attackers and cybercriminals**.
- Threat actors are evolving, and **proactive intelligence** is needed.

Required Skills/Certifications:

- GIAC Certified Threat Intelligence Analyst (GCTI) or similar.
- Experience in **cyber forensics and threat hunting**.

4. Head of Security Architecture & Engineering

Responsibilities:

- Design security solutions for **legacy and cloud-based** banking systems.
- **Also** oversees **application security, secure development, and vulnerability management.**
- Implement **Zero Trust** and **secure integration** between systems.
- Work with IT teams to **modernize security** without disrupting banking operations.

Why It's Critical:

- The bank has **1970s-1990s systems** that cannot be removed but must be secured.
- Requires **strong expertise in both legacy mainframes and modern security models**.

Required Skills/Certifications:

- CISSP-ISSAP (Security Architecture).
- Strong **cloud security and legacy system** expertise.

5. Director of Identity & Access Management (IAM)

Responsibilities:

- Manage authentication systems and **Multi-Factor Authentication (MFA)**.
- Ensure secure **access controls** for employees, customers, and third-party partners.
- Implement **Privileged Access Management (PAM)** for critical systems.

Why It's Critical:

- Cybercriminals **steal credentials** to access banking systems.

- Weak access control can lead to **fraud and data breaches**.

Required Skills/Certifications:

- Certified Identity and Access Manager (CIAM) or CISSP.

6. Global Head of Security Operations & SOC

Responsibilities:

- Manage **24/7 monitoring of banking networks** to detect cyber threats.
- Oversee **Security Information and Event Management (SIEM)** tools.
- Lead **threat detection, forensics, and incident response** teams.

Why It's Critical:

- Banks are **high-risk targets**; constant monitoring is required.
- Advanced attackers use **stealth techniques**, so **proactive detection** is needed.

Required Skills/Certifications:

- GIAC Security Operations Certified (GSOC) or equivalent.
- Experience in **SIEM, forensics, and malware analysis**.

7. Regional Security Officers (RSOs)

Responsibilities:

- Ensure **compliance with country-specific banking laws**.
- Work with **local regulators and law enforcement**.
- Report **security incidents** affecting regional operations.

Why It's Critical:

- Data **residency laws** in multiple countries require local expertise.
- Cyber threats vary **by region**, requiring specialized response plans.

Required Skills/Certifications:

- CISM, CISSP, or local regulatory security certifications.
- Strong knowledge of **regional cybersecurity regulations**.

8. Cybersecurity Analysts (SOC Tier 1, 2, 3)

Responsibilities:

- **Tier 1:** Monitor alerts and escalate potential threats.
- **Tier 2:** Investigate alerts, analyse logs, and perform deeper threat analysis.
- **Tier 3:** Conduct **threat hunting, forensics, and malware reverse engineering**.

Why It's Critical:

- **First line of defence** against cyberattacks.
- SOC analysts ensure quick **incident detection and response**.

Required Skills/Certifications:

- CompTIA Security+, CEH (Tier 1).
- GIAC Certified Incident Handler (Tier 2 & 3).
- Malware analysis and forensics (Tier 3).

Conclusion

The bank's **cybersecurity structure** balances **global oversight with local expertise**. The **hybrid model** allows for centralized policy control while **regional officers ensure compliance**. Each role is carefully designed to tackle **legacy system risks, compliance challenges, modern cyber threats, and strict data residency laws**.

c. Performance Metrics for Cybersecurity Roles in the International Bank

To measure the effectiveness of the bank's cybersecurity team, **Key Performance Indicators (KPIs)** are defined for each role. These KPIs align with **security objectives**, such as compliance, threat detection, and incident response.

1. Role-Based Key Performance Indicators (KPIs)

Chief Information Security Officer (CISO)

KPI	Measurement Criteria	Tracking Method
% of board meetings with cybersecurity risk updates	Number of meetings where security risk updates are presented	Board reports
% reduction in security incidents over time	Comparison of incidents year over year	Incident reports
% compliance with PCI-DSS, GDPR, SOX	Compliance audit results	Internal security audits
Time to approve and implement new security policies	Days taken to finalize and roll out policies	Policy change logs

Director of Security Compliance & Risk Management

KPI	Measurement Criteria	Tracking Method
% of audits passed without major findings	Number of successful regulatory audits	Compliance dashboards
% adherence to compliance policies in different regions	Regional compliance assessment reports	Audit reports
Number of security policy violations detected and resolved	Identified vs. remediated policy breaches	Compliance tracking system

Global Threat Intelligence Director

KPI	Measurement Criteria	Tracking Method
Average time to detect emerging threats	Time taken from threat emergence to detection	Threat intelligence reports
Number of intelligence reports shared with SOC teams	Frequency of intelligence updates provided	SOC reports
% of threats mitigated before exploitation	Number of threats identified and neutralized before attack execution	SIEM logs

Head of Security Architecture & Engineering

KPI	Measurement Criteria	Tracking Method
% of legacy systems with updated security controls	Systems upgraded with modern security measures	System security reports
% of cloud and on-premise systems with Zero Trust implementation	Number of systems adhering to Zero Trust policies	Security architecture audits
Time taken to patch critical vulnerabilities	Days taken to implement security patches	Vulnerability management tools

Director of Identity & Access Management (IAM)

KPI	Measurement Criteria	Tracking Method
% of privileged accounts audited regularly	Frequency of privileged access reviews	IAM logs
% of users with Multi-Factor Authentication (MFA) enabled	MFA adoption across employees and customers	Authentication system reports
Time to revoke access for terminated employees	Time from termination to access removal	Privilege access review system

Global Head of Security Operations & SOC

KPI	Measurement Criteria	Tracking Method
Mean Time to Detect (MTTD) security incidents	Average time from incident occurrence to detection	SOC dashboards
Mean Time to Respond (MTTR) to security threats	Average time taken to resolve security incidents	Incident response tracking
% of false positives in SIEM alerts	Ratio of false positives to total alerts	SIEM event logs

Regional Security Officers (RSOs)

KPI	Measurement Criteria	Tracking Method
% compliance with local security regulations	Regional compliance adherence score	Local audit reports

Time taken to respond to regional security threats	Average incident resolution time	Incident tracking tools
Number of local regulatory violations	Count of reported regulatory non- compliance cases	Compliance system logs

Cybersecurity Analysts (SOC Tier 1, 2, 3)

KPI	Measurement Criteria	Tracking Method
% of alerts investigated within SLA	Alerts processed within the response timeframe	SOC case management system
Number of incidents escalated correctly	Ratio of correct vs. incorrect escalations	Incident tracking system
% of successful threat mitigations	Number of threats effectively neutralized	SOC performance reports

2. Team-Based Security Performance Measurements

Security Function	Measurement Criteria	Tracking Method
Incident Response Efficiency	Time taken from threat detection to resolution	SOC team reports
Vulnerability Management	% of patched vulnerabilities within SLA	Vulnerability scanning tools
Compliance Score	Overall compliance adherence across regions	Compliance assessment reports
Phishing Simulation Results	Click rate on phishing tests conducted for employees	Security awareness training reports

3. Tracking & Reporting Metrics

- **Automated Dashboards:** Use SIEM, SOAR, and compliance tools to track KPIs in real time.
- **Quarterly Security Reports:** Present KPI progress to board members and audit committees.
- **Weekly SOC Briefings:** Share threat intelligence updates and incident response summaries.
- **Annual Cybersecurity Review:** Assess overall security posture improvements and gaps.

4. Alignment with Security Objectives

- **Stronger Threat Detection & Response:** Metrics ensure faster reaction to cyber threats.
- **Regulatory Compliance:** KPI tracking helps maintain 100% compliance across regions.
- **Legacy & Cloud Security:** Performance metrics drive better integration between old and new systems.
- **Continuous Improvement:** Analysing KPIs allows ongoing enhancement of security strategies.

This KPI-driven approach ensures that cybersecurity is measurable, accountable, and aligned with business goals.

Security Policy and Implementation Strategy for International-Bank

1. Policy Header

- **Policy Title:** Enterprise Cybersecurity Policy
- **Policy Number/ID:** SEC-001
- **Version Number and Date:** v1.0, 2/3/2025
- **Approval Authority:** Chief Information Security Officer (CISO)
- **Next Review Date:** 10/3/2025

---

2. Introduction

Purpose Statement

This policy establishes a security framework to protect financial transactions, customer data, and critical infrastructure from advanced cyber threats while ensuring compliance with global and regional banking regulations.

Scope

Applies to:

- All employees, contractors, and third-party vendors.
- IT infrastructure, including cloud applications and legacy mainframe systems.
- Data processing, storage, and transmission systems in all operational regions.

Background/Context

- The bank operates in 30+ countries, managing a mix of modern cloud platforms and legacy mainframes from the 1970s-1990s.

- It faces compliance obligations including **PCI-DSS, GDPR, SOX**, and country-specific banking laws.
- The security architecture is fragmented due to multiple acquisitions, complicating threat detection and response.
- Data residency laws restrict cloud adoption in several jurisdictions.

---

3. Policy Statement

Core Policy Declarations

- All financial and customer data must be encrypted in transit and at rest.
- Multi-factor authentication (MFA) is required for all critical systems.
- Continuous security monitoring and threat detection must be implemented across all IT environments.
- Strict access controls and identity governance must be enforced.

Risk-Based Justification

- Encryption protects against unauthorized data access and compliance breaches.
- MFA reduces credential theft risks, mitigating unauthorized access.
- Continuous monitoring addresses the challenges of fragmented security architectures.
- Strict access controls help secure legacy systems that cannot be decommissioned.

Alignment with Standards/Regulations

- **PCI-DSS**: Secure cardholder data and transaction security.
- **GDPR**: Data protection and privacy controls.
- **SOX**: IT controls over financial reporting.
- **Local Banking Laws**: Compliance with jurisdictional data residency rules.

4. Roles and Responsibilities

Policy Owner

- **Chief Information Security Officer (CISO)**

Implementation Responsibilities

- **IT Security Team:** Deploy and manage security controls.
- **Compliance Team:** Ensure adherence to regulatory requirements.
- **Operations Team:** Enforce security policies within business functions.

Enforcement Authority

- **Security Operations Center (SOC)** monitors compliance and responds to security incidents.

User/Employee Responsibilities

- Follow security protocols and report potential threats.
- Complete regular security awareness training.

---

5. Requirements and Controls

Technical Controls

- **End-to-End Encryption**: TLS 1.2+ for all transactions.
- **Zero Trust Architecture (ZTA)**: Verification of all access requests.
- **Security Information and Event Management (SIEM)**: Unified monitoring across legacy and modern systems.

- **Data Loss Prevention (DLP)**: Automated monitoring to prevent unauthorized data transfers.

Administrative Controls

- **Risk-Based Access Controls (RBAC)** aligned with job functions.
- **Incident Response Playbooks** for breach handling.
- **Third-Party Vendor Assessments** to evaluate security risks.

Physical Controls

- **Data Center Access Controls** (biometric authentication, video surveillance).
- **Hardware Security Modules (HSMs)** for cryptographic key management.

Minimum Security Standards

- Mandatory security patches within **48 hours** of release.
- Endpoint protection for all employee devices.

Environment-Specific Requirements

- Legacy mainframe security through **network segmentation and enhanced logging**.
- **Cloud security configurations** tailored for compliant jurisdictions.

---

6. Compliance and Enforcement

Monitoring Methods

- **AI-driven anomaly detection** for fraud prevention.
- **Continuous vulnerability scanning**.

Measurement Criteria

- Number of detected and mitigated threats per quarter.
- Employee security awareness training completion rates.

Non-Compliance Consequences

- Disciplinary action, including potential termination.
- Mandatory retraining for minor infractions.

Exception Process

- Security exceptions must be approved by the **Risk Committee**.

---

7. Incident Response

Detection and Reporting

- Employees must report incidents within **one hour**.

Response Procedures

- Containment, eradication, and recovery actions.

Escalation Path

- High-priority incidents escalated to **CISO and executive leadership**.

---

8. Supporting Information

- **Definitions:** Cybersecurity terms and acronyms.
- **References:** Regulatory and policy frameworks.
- **Appendices:** Compliance checklists, security training materials.

---

9. Document Control

- **Revision History:** Changes tracked.
- **Distribution List:** Policy recipients.

Implementation Strategy

1. Organizational Structure Strategy

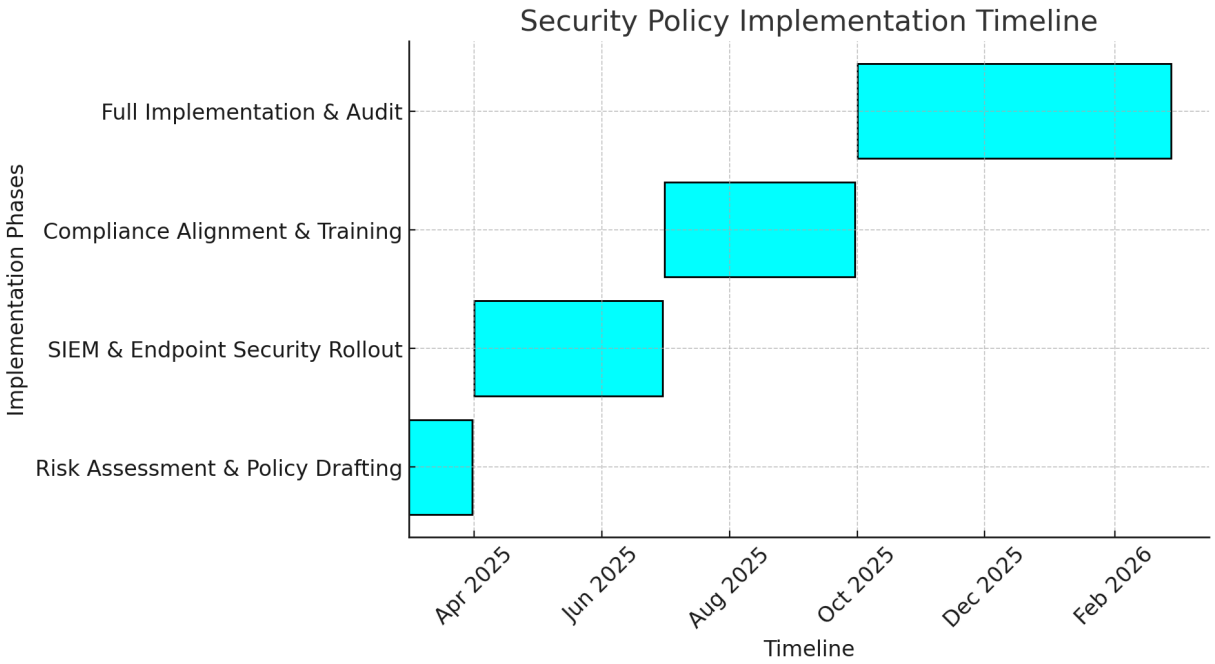
- Centralized **Cybersecurity Governance Board** to oversee policy implementation.
- Unified **Security Operations Center (SOC)** for cross-platform threat monitoring.
- Country-specific **Compliance Officers** ensuring local regulation adherence.

2. Challenges and Potential Resistance

- **Legacy Systems:** Cannot be easily modernized → Use **enhanced monitoring** and **segmentation**.
- **Data Residency Laws:** Limit cloud migration → Adopt **hybrid cloud** and **regional data centers**.
- **Acquisition-Related Fragmentation:** Different security tools across regions → Implement **SIEM integration**.
- **Employee Resistance to New Security Controls:** Address with **awareness training**.

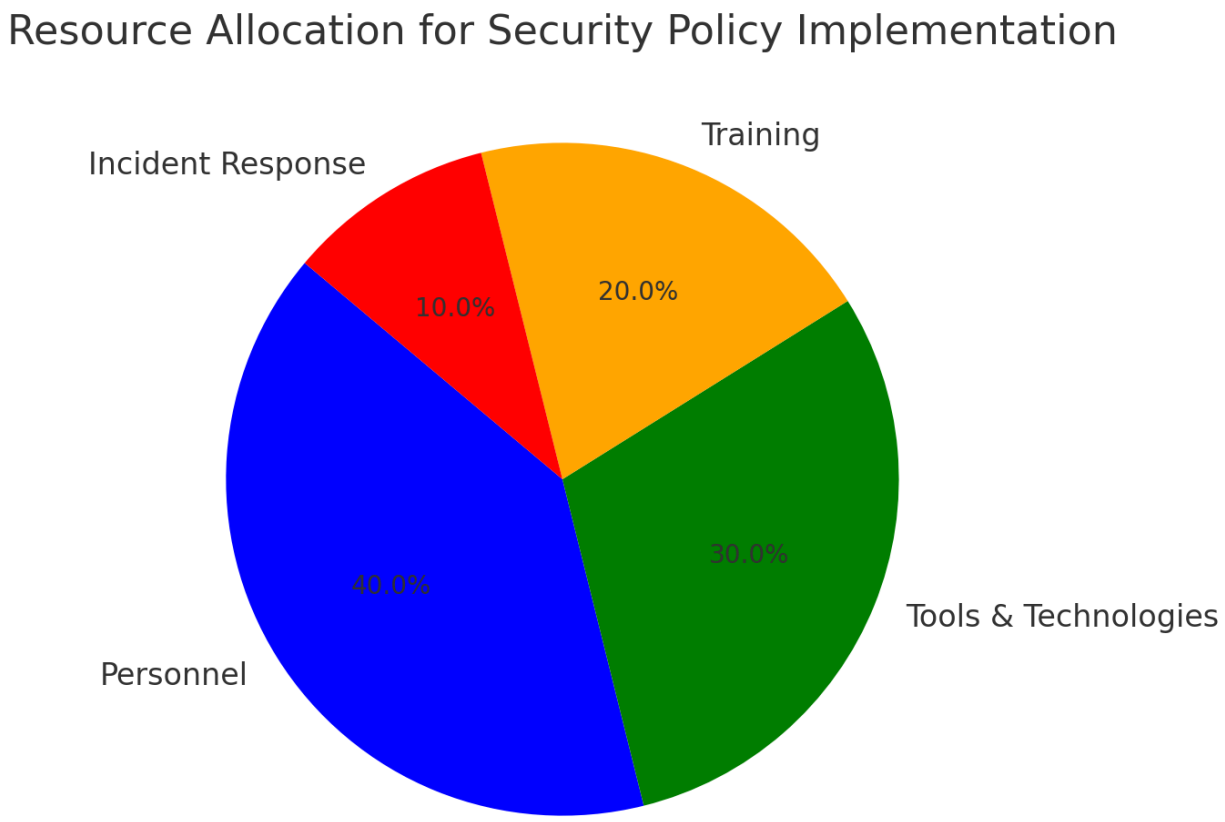
3. Timeline for Establishing the Security Program

Phase	Action	Timeline
Phase 1	Risk Assessment & Policy Drafting	1 Month
Phase 2	SIEM & Endpoint Security Rollout	3 Months
Phase 3	Compliance Alignment & Training	6 Months
Phase 4	Full Implementation & Audit	9-12 Months



4. Resource Requirements & Budget

- **Personnel:** Security engineers, compliance analysts, incident responders.
- **Tools & Technologies:** SIEM, ZTA framework, DLP solutions.
- **Training Costs:** Regular security drills and compliance workshops.

Budget Distribution for Security Policy Implementation

Resource Type	Budget Allocation (%)
Personnel	40%
Tools & Technologies	30%
Training	20%
Incident Response	10%